COMPTIA SECURITY+ SY0-701 DOMÍNIO 5 · GESTÃO DE PROGRAMA DE SEGURANÇA E GOVERNANÇA (20%)

Security+ 5.2 · Business Impact Analysis

Mestre CyberSec · **Aula 5.2 — Business Impact Analysis** (2:55) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: BIA: impacto de negócio se o processo crítico PARAR. MTR/MTTR (tempo de resposta); MTTU (mean time to use); MTBF (mean time between failure). Alimenta RTO/RPO.

💡 Highlights que a prova CompTIA cobra

- BIA: quanto o negócio PERDE por hora/dia se processo critico para
- MTTR: tempo de resposta/reparo; MTBF: confiabilidade

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'evaluates impact of losing critical process'=BIA

🧯 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 5.2 — Business Impact Analysis)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Análise de Impacto nos Negócios (BIA)
Processo formal que avalia o impacto potencial nos negócios da perda de um processo, sistema ou serviço crítico e determina requisitos que alimentam RTO e RPO.

⚠ ***Armadilha CompTIA:*** *Gatilho: 'evaluates impact of losing critical process' = BIA. Não é o plano de recuperação; é a análise que define o que precisa ser recuperado e com que prioridade.*

• Objetivo de Tempo de Recuperação (RTO)
Tempo máximo aceitável que um processo crítico pode ficar indisponível antes de ocorrer impacto inaceitável; é o tempo-alvo para restaurar o serviço.

⚠ ***Armadilha CompTIA:*** *Se a questão pergunta 'quanto tempo pode ficar parado?', é RTO. RTO é objetivo; MTTR é o tempo médio real de reparo.*

• Objetivo de Ponto de Recuperação (RPO)
Quantidade máxima aceitável de perda de dados medida em tempo desde o último backup ou ponto de recuperação válido.

⚠ ***Armadilha CompTIA:*** *Se a questão fala 'quanto dado posso perder?' ou 'backup deve ser de quantas horas atrás?', é RPO.*

• Tempo Médio de Reparo (MTTR)
Tempo médio necessário para reparar ou restaurar um componente ou sistema com falha após a ocorrência da falha.

⚠ ***Armadilha CompTIA:*** *Confiabilidade operacional: tempo médio de resposta/reparo. Não confundir com RTO (objetivo de recuperação) nem com MTBF (tempo entre falhas).*

• Tempo Médio Entre Falhas (MTBF)
Tempo médio entre falhas de um sistema ou componente reparável; um MTBF maior indica maior confiabilidade.

⚠ ***Armadilha CompTIA:*** *Gatilho: 'reliability' ou 'tempo entre falhas' = MTBF. Aplicável a itens reparáveis; não é o mesmo que MTTF.*

• Tempo Médio Até a Falha (MTTF)
Tempo médio esperado até que um componente ou sistema não reparável falhe; usado como métrica de confiabilidade e vida útil do ativo.

⚠️ ***Armadilha CompTIA:*** *MTTF é para itens não reparáveis; MTBF é para itens reparáveis. Se a questão mencionar vida útil esperada de um disco/componente, pense MTTF.*

• Tempo Máximo Tolerável de Indisponibilidade (MTD)
Tempo total máximo que um processo de negócio pode ficar indisponível antes de a organização sofrer impacto inaceitável ou irreversível.

⚠️ ***Armadilha CompTIA:*** *RTO deve ser menor ou igual ao MTD. Se a questão descreve o limite absoluto antes de dano inaceitável, é MTD.*

• Tempo Médio para Uso (MTTU)
Métrica secundária de BIA/BC para o tempo médio necessário até que um recurso restaurado ou recuperado possa ser efetivamente usado de forma produtiva pelo processo de negócio.

⚠️ ***Armadilha CompTIA:*** *Não é o acrônimo mais cobrado; o foco CompTIA é BIA, RTO/RPO, MTTR/MTBF/MTTF. Se aparecer, diferencie 'restaurado' de 'utilizável pelo negócio'.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Análise de Impacto no Negócio (Business Impact Analysis - BIA)

🏠 **Analogia Intuitiva:** A triagem de emergência de um hospital durante uma falta de energia elétrica total na cidade: a diretoria médica analisa quais equipamentos sustentam a vida humana (respiradores mecânicos da UTI que não podem parar nem 1 segundo sem gerar mortes) versus serviços secundários (o sistema de faturamento de convênios médicos, que pode ficar desligado por dois dias sem matar ninguém). A BIA prioriza o que é vital para a sobrevivência do organismo.

🔍 **Causa Raiz / Por que foi criado:** Durante catástrofes, equipes de TI tentam restaurar servidores aleatórios que não são críticos para as receitas da empresa, deixando sistemas vitais inoperantes e causando a falência da organização.

🛡️ **Visão do Auditor de GRC:** Verificar se a BIA mapeia todas as funções críticas de negócio (Critical Business Functions), dependências de sistemas, perda financeira por hora de inatividade e se serviu de base formal para a elaboração do BCP e DRP.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'formal process to identify mission-critical business systems, quantify financial and operational impacts of disruptions, and establish recovery objectives' = Business Impact Analysis (BIA).

📌 Objetivo de Tempo de Recuperação (RTO) vs Tempo Máximo Tolerável de Inatividade (MTD)

🏠 **Analogia Intuitiva:** O tempo de oxigênio em um submarino submerso com avaria. O MTD (Tempo Máximo Tolerável de Inatividade) é o tempo absoluto que a tripulação consegue sobreviver respirando o ar dos tanques antes da asfixia fatal (ex: 8 horas). O RTO (Recovery Time Objective) é a meta agressiva dos engenheiros para consertar o motor e emergir na superfície (ex: 3 horas), garantindo uma folga segura bem antes de atingir o limite fatal do MTD.

🔍 **Causa Raiz / Por que foi criado:** A ausência de metas de tempo de recuperação claras faz com que técnicos restaurem sistemas lentamente, ultrapassando o limite financeiro suportável pelo negócio e causando danos contratuais irremediáveis.

🛡️ **Visão do Auditor de GRC:** Auditar a regra inviolável: RTO deve ser sempre menor ou igual ao MTD (RTO <= MTD). Testar planos de Disaster Recovery para verificar se a restauração prática atinge o RTO acordado no contrato.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'the maximum acceptable amount of time that a system or business service can be offline before normal operations are restored' = Recovery Time Objective (RTO). 'Maximum time business can survive' = MTD.

📌 Objetivo de Ponto de Recuperação (Recovery Point Objective - RPO)

🏠 **Analogia Intuitiva:** O livro-caixa de uma mercearia movimentada. Se o dono da mercearia fecha o caixa e salva uma cópia dos comprovantes de vendas de hora em hora, caso o sistema pife às 16h50, ele perderá no máximo 50 minutos de anotações (o RPO é de 1 hora de tolerância de perda de dados). Se a mercearia for uma bolsa de valores de alta velocidade, o RPO tolerado é zero: cada centavo transacionado precisa ser espelhado em tempo real no cofre.

🔍 **Causa Raiz / Por que foi criado:** Fazer backups com intervalos espaçados demais (ex: backup semanal) achando que isso basta, descobrindo após um desastre que a perda de 6 dias de transações comerciais custará milhões de dólares.

🛡️ **Visão do Auditor de GRC:** Conferir o cronograma de backups e replicação contínua contra a declaração de RPO dos dados: se o RPO do negócio é de 2 horas, a rotina de snapshot/backup deve rodar em intervalos menores que 2 horas.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'the maximum amount of data loss, measured in time, an organization can tolerate after an outage' = Recovery Point Objective (RPO). Sempre relacionado a BACKUP e DADOS.

📌 Métricas de Confiabilidade do Hardware: MTBF (Falhas) vs MTTR (Reparo)

🏠 **Analogia Intuitiva:** Um caminhão de entrega de encomendas rodando pelo país. O MTBF (Mean Time Between Failures) é o tempo médio que o motor aguenta rodando nas estradas sem quebrar (ex: funciona 15.000 horas sem falhas - quanto MAIOR, mais robusto é o caminhão). O MTTR (Mean Time to Repair) é o tempo médio que o mecânico da concessionária leva para trocar uma peça defeituosa e colocar o caminhão de volta na estrada (ex: 3 horas - quanto MENOR, mais ágil é a manutenção).

🔍 **Causa Raiz / Por que foi criado:** Comprar servidores ou discos rígidos de linha doméstica para o datacenter sem checar especificações de durabilidade de componentes industriais e sem peças sobressalentes no almoxarifado.

🛡️ **Visão do Auditor de GRC:** Avaliar os contratos de suporte de hardware: verificar se peças de substituição possuem garantia de entrega em 4 horas (reduzindo MTTR) e se equipamentos críticos possuem redundância (N+1) para cobrir o MTBF.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'average operational lifespan of a device before unexpected hardware breakdown occurs' = MTBF (Mean Time Between Failures). 'Average time required to fix and restore a failed component' = MTTR (Mean Time to Repair).

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Comitê de crise conduz estudo formal para identificar quais serviços de TI geram o maior prejuízo financeiro a cada hora fora do ar	**Análise de Impacto no Negócio (Business Impact Analysis - BIA)**
Contrato estabelece que o sistema de emissão de passagens aéreas deve voltar a funcionar em no máximo 4 horas após uma pane	**Objetivo de Tempo de Recuperação: RTO = 4h (Recovery Time Objective)**
Banco tolera perder no máximo 15 minutos de registros de transações de caixas eletrônicos, exigindo sincronização de banco de dados a cada 15 min	**Objetivo de Ponto de Recuperação: RPO = 15 min (Recovery Point Objective)**
Fabricante de discos rígidos especifica que seus componentes corporativos funcionam em média 1.200.000 horas antes de quebrarem	**Tempo Médio Entre Falhas (Mean Time Between Failures - MTBF)**
Equipe de manutenção mecânica leva em média 2 horas para substituir uma fonte de alimentação queimada e restabelecer o servidor	**Tempo Médio de Reparo (Mean Time to Repair - MTTR)**
Tempo limite absoluto que uma empresa consegue ficar com a fábrica parada antes de falir definitivamente	**Tempo Máximo Tolerável de Inatividade (Maximum Tolerable Downtime - MTD)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

A equipe de admissão de um hospital conclui uma BIA para seu processo de registro de pacientes. Os executivos afirmam que o registro pode ficar indisponível por no máximo quatro horas antes que a segurança do paciente e a receita sejam seriamente afetadas. Qual métrica os executivos definiram?

A) Objetivo de ponto de recuperação (RPO) para atender a normas regulatórias obrigatórias de governança

B) Tempo médio de reparo (MTTR) dentro dos limites formais de apetite a risco da organização

C) Tempo máximo tolerável de inatividade (MTD)

D) Tempo médio entre falhas (MTBF)

QUESTÃO 2 · CENÁRIO DE EXAME

A BIA de uma varejista on-line afirma que o sistema de processamento de pedidos deve voltar a funcionar em até três horas após uma interrupção, e que no máximo dez minutos de dados de transação podem ser perdidos. Qual par de métricas corresponde a esses requisitos?

A) RTO de três horas e RPO de dez minutos

B) RPO de três horas e RTO de dez minutos

C) MTBF de três horas e MTTR de dez minutos

D) MTD de três horas e MTTF de dez minutos

QUESTÃO 3 · CENÁRIO DE EXAME

Um analista de segurança revisa seis meses de logs de um servidor de banco de dados. O servidor falhou quatro vezes, com média de 45 dias entre falhas, e cada reparo levou cerca de 3 horas. Qual valor deve ser relatado como o tempo médio entre falhas?

A) 3 horas

B) 45 dias

C) 4 falhas

D) 48 dias

QUESTÃO 4 · CENÁRIO DE EXAME

Uma empresa usa switches de rede que são substituídos, em vez de reparados, quando falham. Dados históricos mostram que um switch opera por cerca de cinco anos antes de falhar. Qual métrica descreve melhor essa média de cinco anos?

A) Tempo médio entre falhas (MTBF)

B) Tempo médio de reparo (MTTR)

C) Objetivo de ponto de recuperação (RPO)

D) Tempo médio até falha (MTTF)

QUESTÃO 5 · CENÁRIO DE EXAME

Durante a BIA de um sistema de folha de pagamento, a equipe documenta que a folha deve ser restaurada em até 24 horas e que até 4 horas de dados de folha podem ser perdidos. Quais métricas devem ser usadas para expressar esses dois requisitos?

A) RTO de 24 horas e RPO de 4 horas

B) MTBF de 24 horas e MTTR de 4 horas

C) MTD de 24 horas e MTTF de 4 horas

D) RPO de 24 horas e RTO de 4 horas

QUESTÃO 6 · CENÁRIO DE EXAME

Após um incidente de ransomware, um servidor de arquivos é tecnicamente restaurado em duas horas, mas permissões e índices de busca são reconstruídos nos 90 minutos seguintes antes que a equipe consiga usar o drive compartilhado. Qual métrica captura o tempo adicional até que o serviço restaurado seja realmente utilizável pelo negócio?

A) Objetivo de ponto de recuperação (RPO)

B) Tempo médio entre falhas (MTBF)

C) Tempo médio para uso (MTTU)

D) Tempo médio até falha (MTTF)

QUESTÃO 7 · CENÁRIO DE EXAME

Uma BIA mostra que um aplicativo de processamento de pagamentos tem um tempo máximo tolerável de inatividade de oito horas. O plano de recuperação de desastres afirma que o aplicativo será restaurado em doze horas. Qual é o risco mais significativo nesse plano?

A) A meta de perda de dados é maior que o cronograma de backup sob acordos formais de nível de serviço e operação

B) A taxa de falha de hardware é maior que o tempo de reparo.

C) O ponto de restauração é anterior ao ponto de recuperação.

D) A meta de recuperação é posterior ao que o negócio pode tolerar.

QUESTÃO 8 · CENÁRIO DE EXAME

Um sistema de processamento de sinistros tem um RPO de 15 minutos, mas seu banco de dados é submetido a backup apenas uma vez por noite. Qual ação alinha melhor a estratégia de backup ao requisito da BIA?

A) Reduzir o MTTR adicionando servidores reserva demonstrando diligência e cuidado devidos juridicamente defensáveis

B) Aumentar a frequência de backup para que no máximo 15 minutos de dados sejam perdidos.

C) Aumentar o MTBF substituindo discos antigos fornecendo métricas quantitativas de risco para a diretoria

D) Aumentar o RTO para 24 horas para corresponder ao cronograma de backup para atender a normas regulatórias obrigatórias de governança

QUESTÃO 9 · CENÁRIO DE EXAME

Uma BIA de uma empresa de comércio eletrônico descobre que o processamento de pedidos para quando o gateway de pagamento externo fica indisponível, mesmo que os servidores da própria empresa continuem on-line. O que a BIA deve documentar sobre o gateway de pagamento?

A) É uma dependência de um processo crítico de negócio, e o impacto de sua indisponibilidade deve ser incluído no planejamento de recuperação.

B) Está fora do escopo da BIA porque é gerenciado por terceiros fornecendo métricas quantitativas de risco para a diretoria

C) Afeta apenas o RPO e não o RTO para atender a normas regulatórias obrigatórias de governança

D) Pode ser ignorado porque os servidores internos têm MTBF alto dentro dos limites formais de apetite a risco da organização

QUESTÃO 10 · CENÁRIO DE EXAME

Um data center monitora fontes de alimentação que são trocadas quando falham. Uma fonte normalmente opera por 18 meses antes de falhar, e a substituição leva 30 minutos. Qual mapeamento de métricas está correto?

A) MTBF é 30 minutos, e MTTF é 18 meses.

B) MTTR é 18 meses, e MTBF é 30 minutos.

C) RTO é 18 meses, e RPO é 30 minutos.

D) MTTF é 18 meses, e MTTR é 30 minutos.

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa C — Tempo máximo tolerável de inatividade (MTD)

MTD é o tempo máximo que um processo crítico de negócio pode ficar indisponível antes de um impacto inaceitável. RTO é o tempo-alvo de restauração e deve ser menor ou igual ao MTD; RPO define perda tolerável de dados; MTBF mede confiabilidade entre falhas.

Questão 2: Alternativa A — RTO de três horas e RPO de dez minutos

RTO é o tempo máximo aceitável para restaurar o serviço; RPO é a perda máxima aceitável de dados. Portanto, três horas é RTO e dez minutos é RPO. As demais opções invertem os conceitos ou usam métricas de confiabilidade/reparo que não expressam requisitos de recuperação.

Questão 3: Alternativa B — 45 dias

O MTBF é o tempo médio entre falhas de um sistema reparável, calculado a partir do tempo operacional dividido pelo número de falhas. Aqui, 45 dias é o MTBF. 3 horas é o MTTR; 4 é a contagem de falhas; 48 dias soma incorretamente o reparo ao intervalo.

Questão 4: Alternativa D — Tempo médio até falha (MTTF)

MTTF é usado para ativos não reparáveis e representa o tempo médio até a falha. MTBF se aplica a sistemas reparáveis; MTTR é o tempo de reparo; RPO é a perda tolerável de dados, não a vida útil do equipamento.

Questão 5: Alternativa A — RTO de 24 horas e RPO de 4 horas

RTO é o tempo-alvo para restauração do serviço; RPO é a perda máxima tolerável de dados. Portanto, 24 horas é RTO e 4 horas é RPO. MTBF, MTTR e MTTF medem confiabilidade e reparo, não os requisitos de recuperação definidos pela BIA.

Questão 6: Alternativa C — Tempo médio para uso (MTTU)

MTTU representa o tempo médio até que um recurso recuperado fique realmente utilizável pelo negócio, além do reparo técnico. MTBF mede confiabilidade entre falhas; MTTF mede tempo até falha de ativo não reparável; RPO trata de perda de dados.

Questão 7: Alternativa D — A meta de recuperação é posterior ao que o negócio pode tolerar.

O RTO de 12 horas excede o MTD de 8 horas, então a recuperação planejada ocorreria depois do limite tolerável pelo negócio. O RTO deve ser menor ou igual ao MTD. As outras opções confundem RPO, MTBF/MTTR ou invertem termos de recuperação.

Questão 8: Alternativa B — Aumentar a frequência de backup para que no máximo 15 minutos de dados sejam perdidos.

O RPO define a perda máxima tolerável de dados; backups noturnos não conseguem atender a 15 minutos de perda. É necessário aumentar a frequência de backup ou usar replicação. MTTR e MTBF afetam disponibilidade/confiabilidade; alterar o RTO não corrige a perda de dados.

Questão 9: Alternativa A — É uma dependência de um processo crítico de negócio, e o impacto de sua indisponibilidade deve ser incluído no planejamento de recuperação.

A BIA deve mapear dependências de processos críticos, incluindo serviços de terceiros. Se a indisponibilidade do gateway interrompe o negócio, seu impacto precisa ser analisado e considerado nos planos de recuperação. Ele não está fora do escopo, não afeta apenas RPO e não pode ser ignorado por causa do MTBF interno.

Questão 10: Alternativa D — MTTF é 18 meses, e MTTR é 30 minutos.

Como as fontes não são reparadas, mas substituídas, o tempo médio até falha é MTTF: 18 meses. O tempo para substituir é MTTR: 30 minutos. MTBF se aplica a sistemas reparáveis; RTO/RPO são metas de recuperação de negócio, não métricas de confiabilidade de hardware.